CloudDesk Technologies

Information Security Policy

1. Authority, scope and objectives

Document control

Policy ID: CD-ISP-001 | Version: 1.0 (wording revision). Proposed effective date: 2026-10-22. Owner: Engineering Lead. Accountable approver: CTO. Review annually and after material changes. Planned next review: 2027-10-22; approval not recorded. These dates are proposals, not an approved schedule. Classification: SYNTHETIC / DEMO.

Status and assumptions

CloudDesk Technologies is a fictional 75-person B2B SaaS company. This model-authored proposed policy is SYNTHETIC / DEMO and requires user review. It has not been approved. Its requirements do not show that controls are in use or effective. It provides no SOC 2 report, ISO certification, external audit or legal compliance conclusion. Review_status: requires_user_review. Approval_status: not_recorded.

Scope and security objectives

This policy covers employees, contractors, service identities, the hosted SaaS service, supporting cloud infrastructure, company endpoints, customer information and backups. Protect confidentiality, integrity and availability through risk decisions suited to the business, controlled access, recovery planning and clear ownership. The Engineering Lead must propose measurable security objectives annually. Record CTO approval and progress before treating targets as agreed.

Roles and accountability

The CTO must set security direction, provide resources and accept risks. The Engineering Lead must coordinate this policy, the risk register and internal reviews. System owners must identify assets, assess risks and track corrective actions. Platform Engineering must carry out assigned technical requirements. Managers must coordinate training and personnel changes. Everyone must report suspected exposure promptly. These responsibilities do not prove that teams are staffed or work is complete.

Information Security Policy

2. Risk, assets and information handling

Risk assessments and register

The Engineering Lead must coordinate risk assessments at least annually, before material service changes and before onboarding vendors that can access information covered by this policy. System owners must record threats, vulnerabilities, affected assets, likelihood, impact, existing safeguards and residual risk. Maintain a risk register with a risk ID, owner, treatment, due date, acceptance decision and review date. The CTO must approve residual risk acceptance. Review open risks quarterly and escalate overdue high-impact actions.

Asset inventory and ownership

System owners must maintain an inventory of systems, devices, services, data stores and vendors covered by this policy. Record each owner, business purpose, classification and dependencies. Update it when assets are acquired, materially changed or retired. This policy requires inventory records but supplies no actual asset list.

Classification and handling

Use Public for information approved for public release; Internal for routine nonpublic business information; Confidential for customer data, contracts and sensitive business information; and Restricted for credentials, private keys and highly sensitive security material. Owners must assign the highest applicable class and review changes. Share nonpublic information only with authorized recipients through approved channels. Check recipients and limit copies. Never put secrets in source code, logs or support exports.

Retention and disposal

Owners must propose retention schedules based on business need, customer commitments and applicable obligations, with review by the appropriate accountable role. Record approved periods and any holds before disposal. Restrict access while information is retained. At end of life, use verified deletion or secure media disposal. This policy sets no retention periods or backup schedules. Public marketing content may be stored unencrypted under the encryption policy; administrative and authentication traffic still require transport protection.

Information Security Policy

3. Access, encryption and supplier oversight

Access Control Policy reference

Follow access_control_policy.pdf (CloudDesk Access Control Policy): use unique user accounts; require multi-factor authentication for administrative access; review user access permissions every quarter; and revoke terminated employee access within 24 hours. Managers and system owners must coordinate requests, approvals and revocation records. These are policy requirements, not proof of implementation.

Encryption and Key Management Policy reference

Follow encryption_key_management_policy.pdf and its editable JSON, CD-ENC-001 v1.0. Use TLS 1.2 or TLS 1.3 for transport covered by that policy and AES-256 at rest for covered production storage and backups. Use managed KMS for production keys. Rotate symmetric key-encryption keys at least every 12 months. Retain older versions only while dependent data or backups need them. Follow the detailed grant, certificate, secrets and destruction requirements. Customer-managed keys and end-to-end encryption are not assumed capabilities.

Security awareness and training

Managers must arrange security awareness training at onboarding and annually thereafter. Cover phishing, safe sharing, credential protection, incident reporting and classification. Give privileged operators and developers role-specific guidance when their responsibilities change. The Engineering Lead must track assigned training, attendance, completion and overdue follow-up. These are required records, not evidence of completed training.

Vendor management oversight

The business owner must assess each vendor before it handles information covered by this policy. Document data access, service criticality, security requirements, available assurance evidence and identified risks. The Engineering Lead must review the assessment, and the CTO must accept material residual risk before use. Agreements must set appropriate confidentiality, incident communication, access termination and data return or deletion terms. Reassess critical vendors annually and after material changes or incidents. Track findings and exit dependencies. Do not presume vendor certifications or assurances.

Information Security Policy

4. Incidents, continuity and recovery governance

Incident reporting and coordination

Everyone must promptly report suspected exposure or disruption to the Engineering Lead through the proposed internal reporting route. This policy supplies no live address or staffed response service. The Engineering Lead must coordinate triage, severity, containment, evidence preservation and an incident record. The CTO must direct material escalation and authorize external communications with relevant advice. Determine contractual and legal notification duties case by case; this policy sets no universal notification deadline.

Incident records and learning

Record discovery time, affected assets and information, decisions, responders, containment, recovery and corrective actions. Restrict evidence access and preserve relevant logs and decision history. After significant incidents, the Engineering Lead must coordinate lessons learned and assign remediation owners and due dates, with CTO review. Follow CD-ENC-001 for suspected key compromise, including emergency access and key-recovery safeguards.

Business continuity and disaster recovery

System owners must identify critical services, dependencies, disruption scenarios and recovery priorities. The CTO must approve proposed recovery time objectives (RTO) and recovery point objectives (RPO) after impact assessment. This policy provides no numerical targets or availability guarantees. Maintain reviewed continuity and recovery procedures covering responsibilities, dependencies and communication plans. Exercise continuity scenarios at least annually and after material changes. Record gaps and corrective actions.

Backup recovery oversight

Follow CD-ENC-001 for encrypted backups, backup-specific key grants and retention of keys needed for recovery. Test a representative encrypted restore at least quarterly. Record integrity, authorized key access and outcome. Owners must compare recovery results with approved continuity objectives and track gaps. This policy provides no backup schedules, data retention periods or successful restore history.

Information Security Policy

5. Reviews, exceptions, records and enforcement

Internal security reviews

The Engineering Lead must coordinate an annual internal review of policy requirements and expected evidence, and report findings and corrective actions to the CTO. Track owners, due dates and closure evidence. Review open findings quarterly. Continue the quarterly access reviews and monthly KMS administrative and decrypt audit-event reviews required by the related policies. Internal review is not an independent audit or certification.

Exceptions and risk acceptance

Before deviating, the system owner must record affected assets and data, the requirement, rationale, risk, compensating safeguards, owner and expiry. The Engineering Lead must assess the request; the CTO must approve or reject it. Exceptions must expire within 90 days and be reviewed monthly. Renewal requires a fresh assessment and approval. Emergency deviations require an incident record and CTO review by the next business day. CD-ENC-001 remains authoritative for encryption exceptions and destructive key approvals. This policy asserts no active exception.

Records and document control

Keep the risk register, asset inventory, assessments and approvals. Keep training records, vendor reviews and access reviews. Also keep records of incidents, recovery exercises and findings, along with exception tickets. Store them in an access-restricted repository with ownership, version history and approved retention schedules. Preserve CD-ENC-001's minimum 12-month retention for KMS audit logs; that period does not apply to all records. This policy supplies no completed evidence or approval signatures.

Enforcement and annual review

Everyone must follow approved policy requirements and report suspected violations. Managers and the CTO must assess proportionate corrective action under applicable agreements and employment processes, with appropriate advice. No automatic sanction is set. The Engineering Lead must review this policy annually and after material incidents or business or technology changes. Record revisions, reviewer feedback and CTO approval before publishing an approved version. Current review_status: requires_user_review. Approval_status: not_recorded.